INFORME FORENSE Y DE RESPUESTA A INCIDENTES

Investigacion Forense Multi-Incidente - Caso Nordic Shadow

ASIFICACION TLP:AMB

Cliente / Entidad:	Sector Energetico Nordico (Operador de Infraestructura Critica)
Organismo Investigador:	CSIRT / IR Estocolmo
Analista SOC L2 a Cargo:	Sebastian Szostak
Fecha de Emision del Informe:	07 de noviembre de 2026
Estado Operacional de la Amenaza:	Activa hasta confirmar contencion
Resumen SHA-256 de Telemetria:	f645d76800097c09f3102d7d4f1cb5c1b2bb286d6cd054ab3daabe62c69d85f0

715	121	6	7	5	~253 MB
Eventos Analizados	Eventos Maliciosos	Incidentes Detectados	Hosts Afectados	IPs Atacantes Externas	Exfiltracion Estimada

AVISO DE CONFIDENCIALIDAD: Este documento contiene informacion forense clasificada como TLP:AMBER. Su distribucion esta estrictamente limitada a los miembros autorizados del equipo de ciberseguridad, direccion tecnica y asesoria juridica del operador energetico. Queda prohibida su reproduccion parcial o total.

PARTE 1 — RESUMEN EJECUTIVO

1.1 Que Ocurrio

Durante el periodo de monitorizacion analizado se detecto una cadena coordinada y multifasetica de incidentes de seguridad que afecto a la infraestructura critica del operador energetico. El motor de correlacion proceso un total de 715 eventos de telemetria SIEM, identificando 121 eventos maliciosos agrupados en 6 incidentes de alta criticidad distribuidos en 7 activos clave (DC-01, APP-SRV01, FS-SRV01, WEB-01, WS-018, WS-023 y WS-031). Los vectores incluyeron ataques externos de password spraying sobre controladores de dominio, intrusiones remotas via fuerza bruta RDP, explotacion de servidores web expuestos mediante web shells, desplazamiento lateral hacia servidores de archivos, exfiltracion masiva de informacion sensible (~253 MB) y ejecucion de comandos destructivos destinados a eliminar instantaneas de volumen (Volume Shadow Copies) como preparacion previa a ransomware.

1.2 Estado de la Amenaza

Estado Formal: Activa hasta confirmar contencion

El estado operacional de la amenaza se califica formalmente como 'Activa hasta confirmar contencion'. A pesar de que varias fases de ataque han concluido su ventana temporal visible, persisten mecanismos de persistencia no erradicados (servicio WinUpdateHelper y tarea programada UpdateCheck en APP-SRV01, asi como la presencia del archivo web shell test.aspx en WEB-01). Asimismo, debido a la naturaleza de las credenciales comprometidas y a la falta de telemetria perimetral completa, no es posible descartar canales durmientes de acceso secundario o movimiento lateral adicional no interceptado.

1.3 Impacto en el Negocio

- **Exfiltracion Confidencial (~253 MB)**
  Transferencia masiva no autorizada de documentacion clasificada de las areas de Finanzas y Asuntos Legales (\FS-SRV01\Finance y \FS-SRV01\Legal) hacia servidores externos a traves de solicitudes HTTP POST acumulando ~253 MB. Riesgo critico de espionaje industrial, fuga de propiedad intelectual y dano reputacional.
- **Borrado de Instantaneas Pre-Ransomware**
  Invocacion de 'vssadmin delete shadows /all /quiet' en estaciones de trabajo y servidores de archivos, inhabilitando la recuperacion local rapida del sistema de archivos. Patron caracteristico de preparacion inmediata para cifrado extorsivo (ransomware).
- **Persistencia en Servidores Criticos de Aplicacion**
  Instalacion del servicio 'WinUpdateHelper' y de la tarea programada '\Microsoft\Windows\UpdateCheck' en APP-SRV01, acoplados a ejecuciones continuas de balizamiento C2 a intervalos regulares sin fluctuacion, permitiendo reconexion autonoma del adversario.
- **Compromiso de Servidor Web Perimetral**
  Explotacion de vulnerabilidad publica e implantacion de web shell 'test.aspx' en WEB-01, otorgando ejecucion remota de comandos bajo el contexto de identidad 'IIS APPPOOL\DefaultAppPool'.

1.4 Cumplimiento Normativo: RGPD y Directiva NIS2

Notificacion RGPD (Articulo 33):
La evidencia forense constata la exfiltracion exitosa de documentos corporativos sensibles que incluyen datos de recursos humanos, contratos legales y transacciones financieras vinculadas a personas fisicas identificables. De conformidad con el Articulo 33 del Reglamento General de Proteccion de Datos (RGPD / GDPR), la entidad tiene la obligacion legal de notificar la brecha de seguridad a la Autoridad de Proteccion de Datos de Suecia (IMY - Integritetsskyddsmyndigheten) dentro del plazo maximo de 72 horas desde que se tuvo constancia del incidente. Asimismo, se debe evaluar el impacto sobre los interesados para determinar la necesidad de comunicacion directa (Art. 34).

Directiva NIS2 (Operador Esencial del Sector Energetico):
Al tratarse de una entidad del sector de la energia catalogada como Operador Esencial bajo la Directiva NIS2 (Directiva UE 2022/2555), rigen los plazos estrictos de notificacion obligatoria de incidentes significativos:

1. Alerta Temprana (24 horas): Emision de una alerta temprana ante la autoridad competente (MSB / CSIRT Nacional de Suecia) dentro de las 24 horas siguientes al conocimiento del incidente con sospecha de intencionalidad o impacto transfronterizo.
2. Notificacion de Incidente (72 horas): Actualizacion con evaluacion inicial de gravedad, consecuencias e indicadores de compromiso.
3. Informe Final (1 mes): Entrega de reporte tecnico y forense exhaustivo con causas raiz, medidas mitigadoras e impacto cuantificado.

1.5 Prioridades Recomendadas de Mitigacion

Prioridad	Accion Operativa	Responsable	Plazo
P1 (Inmediata)	Aislamiento de red de hosts comprometidos (WEB-01, APP-SRV01, FS-SRV01, WS-018, WS-023, WS-031) y bloqueo en firewall perimetral de las 5 IPs atacantes externas.	SecOps / SOC L2	< 2 horas
P2 (Critica)	Revocacion inmediata de tokens y reseteo de contraseñas de cuentas vulneradas (mgarcia, backupsvc, rrojas, admin); remocion de privilegios de admin local a mgarcia en WS-031.	Identity / SysAdmin	< 4 horas
P3 (Regulatoria)	Emision de Alerta Temprana NIS2 ante el CSIRT Nacional (MSB) y preparacion de la notificacion formal ante IMY por brecha de datos personales RGPD Art. 33.	DPO / Legal / CISO	< 24 h (NIS2) / < 72 h (RGPD)
P4 (Erradicacion)	Eliminacion de artefactos de persistencia: borrado de servicio WinUpdateHelper y tarea programada UpdateCheck en APP-SRV01; eliminacion de web shell test.aspx en WEB-01.	Incident Response	< 24 horas
P5 (Resiliencia)	Auditoria de copias de seguridad offline (inmutables/WORM); imposicion estricta de MFA en todos los accesos externos y RDP; despliegue de Sysmon con Hash=SHA256.	Arquitectura TI / CISO	48 a 72 horas

1.6 Matriz de Riesgo por Incidente

Incidente	Titulo Operativo	Nivel de Riesgo	Justificacion de Negocio
INC-01	Password spraying y compromiso de cuenta privilegiada	Alto	Compromiso de credenciales corporativas (mgarcia) en WS-031 con privilegios locales preexistentes.
INC-02	Fuerza bruta RDP, intrusion y movimiento lateral	Alto	Intrusion exitosa sobre cuenta admin hacia APP-SRV01 y salto lateral a FS-SRV01.
INC-03	Actividad previa a ransomware y borrado de copias shadow	Critico	Destruccion de instantaneas de volumen vssadmin y acceso masivo a archivos de red.

Incidente	Titulo Operativo	Nivel de Riesgo	Justificacion de Negocio
INC-04	Exfiltracion masiva de documentos confidenciales via proxy	Critico	Fuga comprobada de ~253 MB de contratos legales y registros financieros hacia servidor externo.
INC-05	Persistencia mediante tarea y servicio con balizamiento C2	Alto	Canal de mando y control persistente en servidor de aplicaciones mediante balizamiento regular.
INC-06	Compromiso de servidor web por web shell y ejecucion remota	Alto	Servidor perimetral WEB-01 comprometido con shell aspx interactiva y reconocimiento local.

PARTE 2 — RESUMEN TECNICO Y EVIDENCIA FORENSE

2.1 Alcance, Metodologia e Integridad de Telemetria

La presente investigacion forense abarca la ingestion y analisis de la telemetria provista en formato SIEM, que integra registros de seguridad de Windows Event Logs (Domain Controllers, servidores miembros y estaciones de trabajo), logs de proxy corporativo HTTP y eventos de monitorizacion de procesos.

Metodologia:

1. Integridad Criptografica: Verificacion de la muestra original mediante calculo de resumen SHA-256.
2. Motor de Correlacion Generico: Aplicacion de 14 reglas de deteccion (R1 a R14) basadas en umbrales estadisticos, patrones LOLBins y ventanas temporales, sin filtros de entidades hardcodeadas.
3. Agrupacion de Incidentes: Algoritmo de clustering temporal y de conectividad con ventana maxima de inactividad de 30 minutos.
4. Taxonomia MITRE ATT&CK: Mapeo de eventos contra tecnicas y tacticas de la matriz Enterprise v14.
5. Extraccion de IoCs: Consolidacion de direcciones IP externas, identidades vulneradas, nombres de host, rutas y artefactos.

Limitaciones: La telemetria provista carece de logs de cortafuegos de borde, registros de VPN, eventos de autenticacion Kerberos (4768/4769) y hashes criptograficos en creacion de procesos (Sysmon EID 1).

2.2 Resumen Consolidado de Incidentes

ID	Titulo	Ventana Temporal	Hosts Afectados	Cuentas	Tecnicas MITRE
INC-01	Password spraying y compromiso de cuenta privilegiada	08:25:00 - 08:40:00	DC-01, WS-031	aperez, backupsvc, dtorres, helpdesk, jlopez, mgarcia, rrojas, slopez	T1078, T1078.003, T1110.001, T1110.003
INC-02	Fuerza bruta RDP, intrusion y movimiento lateral con exfiltracion	09:02:00 - 09:21:00	APP-SRV01, FS-SRV01	admin	T1021.001, T1021.002, T1039, T1041, T1059.001, T1069.001, T1078, T1078.003, T1110.001, T1135, T1560.001
INC-03	Actividad previa a ransomware y borrado de copias shadow	09:36:00 - 09:42:00	FS-SRV01, WS-023	backupsvc	T1059.001, T1083, T1490
INC-04	Exfiltracion masiva de documentos confidenciales via proxy	10:40:00 - 10:49:18	FS-SRV01, WS-018	rrojas	T1039, T1048.002, T1560.001

ID	Titulo	Ventana Temporal	Hosts Afectados	Cuentas	Tecnicas MITRE
INC-05	Persistencia mediante tarea programada y servicio con balizamiento C2	11:37:00 - 12:04:00	APP-SRV01	helpdesk	T1053.005, T1071.001, T1543.003
INC-06	Compromiso de servidor web por web shell y ejecucion remota	12:10:00 - 12:15:00	WEB-01	IIS APPPOOL\DefaultAppPool	T1033, T1190, T1505.003

2.3 Linea de Tiempo Detallada por Incidente (Log_IDs)

A continuacion se desglosa la secuencia cronologica completa de eventos maliciosos agrupados por incidente, indicando el identificador unico de registro (Log_ID), marca temporal, host afectado, cuenta utilizada, Event ID de telemetria, detalle de la linea de comando o solicitud, y severidad asignada.

INC-01 — Password spraying y compromiso de cuenta privilegiada (35 Eventos Correlacionados)

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00057	2026-10-23 08:25:00	DC-01	jlopez	4625	An account failed to log on - bad password	Medio
EVT-00058	2026-10-23 08:25:19	DC-01	aperez	4625	An account failed to log on - bad password	Medio
EVT-00060	2026-10-23 08:25:38	DC-01	helpdesk	4625	An account failed to log on - bad password	Medio
EVT-00061	2026-10-23 08:25:57	DC-01	mgarcia	4625	An account failed to log on - bad password	Medio
EVT-00063	2026-10-23 08:26:16	DC-01	rrojas	4625	An account failed to log on - bad password	Medio
EVT-00065	2026-10-23 08:26:35	DC-01	slopez	4625	An account failed to log on - bad password	Medio
EVT-00066	2026-10-23 08:26:54	DC-01	backupsvc	4625	An account failed to log on - bad password	Medio
EVT-00068	2026-10-23 08:27:13	DC-01	dtorres	4625	An account failed to log on - bad password	Medio
EVT-00069	2026-10-23 08:27:32	DC-01	jlopez	4625	An account failed to log on - bad password	Medio
EVT-00071	2026-10-23 08:27:51	DC-01	aperez	4625	An account failed to log on - bad password	Medio

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00073	2026-10-23 08:28:10	DC-01	helpdesk	4625	An account failed to log on - bad password	Medio
EVT-00074	2026-10-23 08:28:29	DC-01	mgarcia	4625	An account failed to log on - bad password	Medio
EVT-00075	2026-10-23 08:28:48	DC-01	rrojas	4625	An account failed to log on - bad password	Medio
EVT-00077	2026-10-23 08:29:07	DC-01	slopez	4625	An account failed to log on - bad password	Medio
EVT-00078	2026-10-23 08:29:26	DC-01	backupsvc	4625	An account failed to log on - bad password	Medio
EVT-00079	2026-10-23 08:29:45	DC-01	dtorres	4625	An account failed to log on - bad password	Medio
EVT-00081	2026-10-23 08:30:04	DC-01	jlopez	4625	An account failed to log on - bad password	Medio
EVT-00084	2026-10-23 08:30:23	DC-01	aperez	4625	An account failed to log on - bad password	Medio
EVT-00085	2026-10-23 08:30:42	DC-01	helpdesk	4625	An account failed to log on - bad password	Medio
EVT-00086	2026-10-23 08:31:01	DC-01	mgarcia	4625	An account failed to log on - bad password	Medio
EVT-00088	2026-10-23 08:31:20	DC-01	rrojas	4625	An account failed to log on - bad password	Medio
EVT-00092	2026-10-23 08:31:39	DC-01	slopez	4625	An account failed to log on - bad password	Medio
EVT-00094	2026-10-23 08:31:58	DC-01	backupsvc	4625	An account failed to log on - bad password	Medio
EVT-00096	2026-10-23 08:32:17	DC-01	dtorres	4625	An account failed to log on - bad password	Medio
EVT-00099	2026-10-23 08:32:36	DC-01	jlopez	4625	An account failed to log on - bad password	Medio
EVT-00100	2026-10-23 08:32:55	DC-01	aperez	4625	An account failed to log on - bad password	Medio
EVT-00101	2026-10-23 08:33:14	DC-01	helpdesk	4625	An account failed to log on - bad password	Medio

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00104	2026-10-23 08:33:33	DC-01	mgarcia	4625	An account failed to log on - bad password	Medio
EVT-00105	2026-10-23 08:33:52	DC-01	rrojas	4625	An account failed to log on - bad password	Medio
EVT-00107	2026-10-23 08:34:11	DC-01	slopez	4625	An account failed to log on - bad password	Medio
EVT-00108	2026-10-23 08:34:30	DC-01	backupsvc	4625	An account failed to log on - bad password	Medio
EVT-00110	2026-10-23 08:34:49	DC-01	dtorres	4625	An account failed to log on - bad password	Medio
EVT-00111	2026-10-23 08:35:08	DC-01	jlopez	4625	An account failed to log on - bad password	Medio
EVT-00123	2026-10-23 08:39:00	DC-01	mgarcia	4624	An account was successfully logged on	Alto
EVT-00126	2026-10-23 08:40:00	WS-031	mgarcia	4672	Special privileges assigned to new logon	Alto

INC-02 — Fuerza bruta RDP, intrusion y movimiento lateral con exfiltracion (15 Eventos Correlacionados)

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00174	2026-10-23 09:02:00	APP-SRV01	admin	4625	An account failed to log on (LogonType=10: RDP)	Medio
EVT-00175	2026-10-23 09:03:00	APP-SRV01	admin	4625	An account failed to log on (LogonType=10: RDP)	Medio
EVT-00178	2026-10-23 09:04:00	APP-SRV01	admin	4625	An account failed to log on (LogonType=10: RDP)	Medio
EVT-00180	2026-10-23 09:05:00	APP-SRV01	admin	4625	An account failed to log on (LogonType=10: RDP)	Medio
EVT-00188	2026-10-23 09:06:00	APP-SRV01	admin	4624	An account was successfully logged on (LogonType=10: RDP)	Alto
EVT-00193	2026-10-23 09:07:00	APP-SRV01	admin	4672	Special privileges assigned to new logon	Alto
EVT-00198	2026-10-23 09:09:00	APP-SRV01	admin	4688	powershell.exe -NoProfile -EncodedCommand [REDACTED_SYNTHETIC]	Alto

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00207	2026-10-23 09:11:00	APP-SRV01	admin	4104	powershell.exe	Alto
EVT-00214	2026-10-23 09:13:00	APP-SRV01	admin	4688	net.exe view \\FS-SRV01	Alto
EVT-00222	2026-10-23 09:15:00	FS-SRV01	admin	4625	An account failed to log on (LogonType=3; source=APP-SRV01)	Medio
EVT-00225	2026-10-23 09:16:00	FS-SRV01	admin	4624	An account was successfully logged on (LogonType=3; source=APP-SRV01)	Alto
EVT-00227	2026-10-23 09:17:00	FS-SRV01	admin	5140	Network share accessed: \\FS-SRV01\Finance	Alto
EVT-00231	2026-10-23 09:18:00	FS-SRV01	admin	5145	Detailed file share access: Finance\Budget2027.xlsx	Alto
EVT-00232	2026-10-23 09:20:00	APP-SRV01	admin	4688	tar.exe -a -c -f C:\Temp\finance.zip C:\Temp\reports	Alto
EVT-00235	2026-10-23 09:21:00	APP-SRV01	admin	5156	powershell.exe	Alto

INC-03 — Actividad previa a ransomware y borrado de copias shadow (18 Eventos Correlacionados)

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00280	2026-10-23 09:36:00	WS-023	backupsvc	4688	powershell.exe -NoProfile -EncodedCommand <base64_redacted>	Alto
EVT-00284	2026-10-23 09:37:00	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_000.xlsx	Medio
EVT-00286	2026-10-23 09:37:16	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_001.xlsx	Medio
EVT-00289	2026-10-23 09:37:32	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_002.xlsx	Medio
EVT-00290	2026-10-23 09:37:48	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_003.xlsx	Medio
EVT-00291	2026-10-23 09:38:04	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_004.xlsx	Medio
EVT-00293	2026-10-23 09:38:20	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_005.xlsx	Medio

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00296	2026-10-23 09:38:36	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_006.xlsx	Medio
EVT-00298	2026-10-23 09:38:52	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_007.xlsx	Medio
EVT-00300	2026-10-23 09:39:08	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_008.xlsx	Medio
EVT-00302	2026-10-23 09:39:24	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_009.xlsx	Medio
EVT-00303	2026-10-23 09:39:40	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_010.xlsx	Medio
EVT-00305	2026-10-23 09:39:56	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_011.xlsx	Medio
EVT-00306	2026-10-23 09:40:12	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_012.xlsx	Medio
EVT-00307	2026-10-23 09:40:28	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_013.xlsx	Medio
EVT-00308	2026-10-23 09:40:44	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_014.xlsx	Medio
EVT-00309	2026-10-23 09:41:00	FS-SRV01	backupsvc	4663	File access: Finance\FY2026\document_015.xlsx	Medio
EVT-00314	2026-10-23 09:42:00	WS-023	backupsvc	4688	vssadmin.exe delete shadows /all /quiet	Alto

INC-04 — Exfiltracion masiva de documentos confidenciales via proxy (24 Eventos Correlacionados)

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00419	2026-10-23 10:40:00	FS-SRV01	rrojas	5140	A network share object was accessed	Medio
EVT-00428	2026-10-23 10:42:00	WS-018	rrojas	4688	7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx	Alto
EVT-00430	2026-10-23 10:43:00	WS-018	rrojas	PROXY_ACCESS	bytes_out=67737085 uri=/upload/session/1	Alto

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00431	2026-10-23 10:43:18	WS-018	rrojas	PROXY_ACCESS	bytes_out=17278017 uri=/upload/session/2	Alto
EVT-00432	2026-10-23 10:43:36	WS-018	rrojas	PROXY_ACCESS	bytes_out=13916972 uri=/upload/session/3	Alto
EVT-00435	2026-10-23 10:43:54	WS-018	rrojas	PROXY_ACCESS	bytes_out=16895186 uri=/upload/session/4	Alto
EVT-00436	2026-10-23 10:44:12	WS-018	rrojas	PROXY_ACCESS	bytes_out=7196949 uri=/upload/session/5	Alto
EVT-00438	2026-10-23 10:44:30	WS-018	rrojas	PROXY_ACCESS	bytes_out=14427680 uri=/upload/session/6	Alto
EVT-00439	2026-10-23 10:44:48	WS-018	rrojas	PROXY_ACCESS	bytes_out=10427823 uri=/upload/session/7	Alto
EVT-00440	2026-10-23 10:45:06	WS-018	rrojas	PROXY_ACCESS	bytes_out=12043158 uri=/upload/session/8	Alto
EVT-00441	2026-10-23 10:45:24	WS-018	rrojas	PROXY_ACCESS	bytes_out=6167521 uri=/upload/session/9	Alto
EVT-00443	2026-10-23 10:45:42	WS-018	rrojas	PROXY_ACCESS	bytes_out=10696100 uri=/upload/session/10	Alto
EVT-00444	2026-10-23 10:46:00	WS-018	rrojas	PROXY_ACCESS	bytes_out=10360030 uri=/upload/session/11	Alto
EVT-00445	2026-10-23 10:46:18	WS-018	rrojas	PROXY_ACCESS	bytes_out=12453076 uri=/upload/session/12	Alto
EVT-00448	2026-10-23 10:46:36	WS-018	rrojas	PROXY_ACCESS	bytes_out=10366942 uri=/upload/session/13	Alto

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00450	2026-10-23 10:46:54	WS-018	rrojas	PROXY_ACCESS	bytes_out=7997679 uri=/upload/session/14	Alto
EVT-00451	2026-10-23 10:47:12	WS-018	rrojas	PROXY_ACCESS	bytes_out=11952743 uri=/upload/session/15	Alto
EVT-00453	2026-10-23 10:47:30	WS-018	rrojas	PROXY_ACCESS	bytes_out=16798883 uri=/upload/session/16	Alto
EVT-00455	2026-10-23 10:47:48	WS-018	rrojas	PROXY_ACCESS	bytes_out=5846865 uri=/upload/session/17	Alto
EVT-00456	2026-10-23 10:48:06	WS-018	rrojas	PROXY_ACCESS	bytes_out=7860805 uri=/upload/session/18	Alto
EVT-00457	2026-10-23 10:48:24	WS-018	rrojas	PROXY_ACCESS	bytes_out=13060665 uri=/upload/session/19	Alto
EVT-00458	2026-10-23 10:48:42	WS-018	rrojas	PROXY_ACCESS	bytes_out=10726312 uri=/upload/session/20	Alto
EVT-00460	2026-10-23 10:49:00	WS-018	rrojas	PROXY_ACCESS	bytes_out=13316765 uri=/upload/session/21	Alto
EVT-00461	2026-10-23 10:49:18	WS-018	rrojas	PROXY_ACCESS	bytes_out=16778302 uri=/upload/session/22	Alto

INC-05 — Persistencia mediante tarea programada y servicio con balizamiento C2 (7 Eventos Correlacionados)

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00523	2026-10-23 11:37:00	APP-SRV01	helpdesk	4698	TaskName=\Microsoft\Windows\UpdateCheck; Action=powershell.exe -File C:\ProgramData\updatecheck.ps1	Alto
EVT-00524	2026-10-23 11:38:00	APP-SRV01	helpdesk	7045	ServiceName=WinUpdateHelper; ImagePath=C:\ProgramData\wuhelper.exe	Alto

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00528	2026-10-23 11:40:00	APP-SRV01	helpdesk	4688	C:\ProgramData\wuhelper.exe	Alto
EVT-00542	2026-10-23 11:46:00	APP-SRV01	helpdesk	4688	C:\ProgramData\wuhelper.exe	Alto
EVT-00548	2026-10-23 11:52:00	APP-SRV01	helpdesk	4688	C:\ProgramData\wuhelper.exe	Alto
EVT-00559	2026-10-23 11:58:00	APP-SRV01	helpdesk	4688	C:\ProgramData\wuhelper.exe	Alto
EVT-00564	2026-10-23 12:04:00	APP-SRV01	helpdesk	4688	C:\ProgramData\wuhelper.exe	Alto

INC-06 — Compromiso de servidor web por web shell y ejecucion remota (22 Eventos Correlacionados)

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00571	2026-10-23 12:10:00	WEB-01	-	HTTP_ACCESS	/uploads/test.aspx?cmd=whoami	Alto
EVT-00572	2026-10-23 12:10:12	WEB-01	-	HTTP_ACCESS	/login?user=admin	Medio
EVT-00573	2026-10-23 12:10:24	WEB-01	-	HTTP_ACCESS	/uploads/test.aspx?cmd=whoami	Alto
EVT-00574	2026-10-23 12:10:36	WEB-01	-	HTTP_ACCESS	/uploads/test.aspx?cmd=whoami	Alto
EVT-00576	2026-10-23 12:10:48	WEB-01	-	HTTP_ACCESS	/admin/	Medio
EVT-00577	2026-10-23 12:11:00	WEB-01	-	HTTP_ACCESS	/api/v1/export	Medio
EVT-00579	2026-10-23 12:11:12	WEB-01	-	HTTP_ACCESS	/login?user=admin	Medio

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00581	2026-10-23 12:11:24	WEB-01	-	HTTP_ACCESS	/admin/	Medio
EVT-00582	2026-10-23 12:11:36	WEB-01	-	HTTP_ACCESS	/api/v1/export	Medio
EVT-00583	2026-10-23 12:11:48	WEB-01	-	HTTP_ACCESS	/admin/	Medio
EVT-00584	2026-10-23 12:12:00	WEB-01	-	HTTP_ACCESS	/admin/	Medio
EVT-00585	2026-10-23 12:12:12	WEB-01	-	HTTP_ACCESS	/admin/	Medio
EVT-00586	2026-10-23 12:12:24	WEB-01	-	HTTP_ACCESS	/login?user=admin	Medio
EVT-00588	2026-10-23 12:12:36	WEB-01	-	HTTP_ACCESS	/api/v1/export	Medio
EVT-00589	2026-10-23 12:12:48	WEB-01	-	HTTP_ACCESS	/login?user=admin	Medio
EVT-00590	2026-10-23 12:13:00	WEB-01	-	HTTP_ACCESS	/api/v1/export	Medio
EVT-00591	2026-10-23 12:13:12	WEB-01	-	HTTP_ACCESS	/login?user=admin	Medio
EVT-00592	2026-10-23 12:13:24	WEB-01	-	HTTP_ACCESS	/login?user=admin	Medio
EVT-00593	2026-10-23 12:13:36	WEB-01	-	HTTP_ACCESS	/login?user=admin	Medio

Log_ID	Timestamp	Host	Usuario	EID	Detalle / Linea de Comando	Severidad
EVT-00595	2026-10-23 12:13:48	WEB-01	-	HTTP_ACCESS	/login?user=admin	Medio
EVT-00596	2026-10-23 12:14:00	WEB-01	-	HTTP_ACCESS	/api/v1/export	Medio
EVT-00599	2026-10-23 12:15:00	WEB-01	IIS APPPOOL\DefaultAppPool	4688	cmd.exe /c whoami	Alto

2.4 Matriz MITRE ATT&CK Consolidada

Mapeo exhaustivo de las tecnicas de ataque observadas en la investigacion contra la matriz MITRE ATT&CK Enterprise v14, desglosando la tactica, identificador de tecnica, nombre canonico, incidentes donde se manifesto y los identificadores Log_ID que constituyen la evidencia forense.

Tactica	Tecnica	ID	Incidentes	Evidencia Log_ID
Collection	Data from Network Shared Drive	T1039	INC-02, INC-04	EVT-00227, EVT-00231, EVT-00419
Collection	Archive via Utility	T1560.001	INC-02, INC-04	EVT-00232, EVT-00428
Command and Control	Exfiltration Over C2 Channel	T1041	INC-02	EVT-00235
Command and Control	Web Protocols (HTTP Beaconing)	T1071.001	INC-05	EVT-00528, EVT-00542, EVT-00548, EVT-00559, EVT-00564
Credential Access	Password Guessing / Brute Force	T1110.001	INC-01, INC-02	EVT-00057..EVT-00180 (37 evts)
Credential Access	Password Spraying	T1110.003	INC-01	EVT-00057..EVT-00111 (33 evts)
Discovery	System Owner/User Discovery	T1033	INC-06	EVT-00599
Discovery	Local Groups Discovery	T1069.001	INC-02	EVT-00207
Discovery	File and Directory Discovery	T1083	INC-03	EVT-00284..EVT-00309 (16 evts)
Discovery	Network Share Discovery	T1135	INC-02	EVT-00207, EVT-00214
Execution	PowerShell Execution	T1059.001	INC-02, INC-03	EVT-00198, EVT-00280
Exfiltration	Exfiltration Over Asymmetric Non-C2 Protocol	T1048.002	INC-04	EVT-00430..EVT-00461 (22 evts)
Impact	Inhibit System Recovery (Delete Volume Shadows)	T1490	INC-03	EVT-00314
Initial Access	Valid Accounts	T1078	INC-01, INC-02	EVT-00123, EVT-00188
Initial Access	Exploit Public-Facing Application	T1190	INC-06	EVT-00572..EVT-00596 (18 evts)
Lateral Movement	Remote Desktop Protocol	T1021.001	INC-02	EVT-00174, EVT-00175, EVT-00178, EVT-00180, EVT-00188
Lateral Movement	SMB/Windows Admin Shares	T1021.002	INC-02	EVT-00222, EVT-00225
Persistence	Scheduled Task	T1053.005	INC-05	EVT-00523
Persistence	Web Shell	T1505.003	INC-06	EVT-00571, EVT-00573, EVT-00574, EVT-00599
Persistence	Windows Service	T1543.003	INC-05	EVT-00524
Privilege Escalation	Local Accounts	T1078.003	INC-01, INC-02	EVT-00126, EVT-00193

2.5 Indicadores de Compromiso (IoCs)

Consolidacion de artefactos e indicadores de compromiso (IoCs) extraidos del analisis de eventos, clasificados por categoria operativa para su ingestion en sistemas SIEM, EDR y pasarelas perimetrales.

Tipo	Valor / Indicador	Contexto Forense	Incidente	Primer Visto	Ultimo Visto
IP Externa	203.0.113.74	Direccion IP externa involucrada en INC-01 (origen/destino)	INC-01	08:25:00	08:40:00
Cuenta Comprometida	CORP\aperez	Identidad utilizada en actividad maliciosa en INC-01	INC-01	08:25:00	08:40:00
Cuenta Comprometida	CORP\backupsvc	Identidad utilizada en actividad maliciosa en INC-01	INC-01	08:25:00	08:40:00
Cuenta Comprometida	CORP\dtorres	Identidad utilizada en actividad maliciosa en INC-01	INC-01	08:25:00	08:40:00
Cuenta Comprometida	CORP\helpdesk	Identidad utilizada en actividad maliciosa en INC-01	INC-01	08:25:00	08:40:00
Cuenta Comprometida	CORP\jlopez	Identidad utilizada en actividad maliciosa en INC-01	INC-01	08:25:00	08:40:00
Cuenta Comprometida	CORP\mgarcia	Identidad utilizada en actividad maliciosa en INC-01	INC-01	08:25:00	08:40:00
Cuenta Comprometida	CORP\rrojas	Identidad utilizada en actividad maliciosa en INC-01	INC-01	08:25:00	08:40:00
Cuenta Comprometida	CORP\slopez	Identidad utilizada en actividad maliciosa en INC-01	INC-01	08:25:00	08:40:00
Host Afectado	DC-01	Activo corporativo afectado por eventos de INC-01	INC-01	08:25:00	08:40:00
Host Afectado	WS-031	Activo corporativo afectado por eventos de INC-01	INC-01	08:25:00	08:40:00
IP Externa	198.51.100.77	Direccion IP externa involucrada en INC-02 (origen/destino)	INC-02	09:02:00	09:21:00
IP Externa	203.0.113.88	Direccion IP externa involucrada en INC-02 (origen/destino)	INC-02	09:02:00	09:21:00
Cuenta Comprometida	CORP\admin	Identidad utilizada en actividad maliciosa en INC-02	INC-02	09:02:00	09:21:00
Host Afectado	APP-SRV01	Activo corporativo afectado por eventos de INC-02	INC-02	09:02:00	09:21:00
Host Afectado	FS-SRV01	Activo corporativo afectado por eventos de INC-02	INC-02	09:02:00	09:21:00
Archivo/Ruta	C:\Temp\finance.zip	Artefacto o archivo manipulado en INC-02	INC-02	09:02:00	09:21:00
Archivo/Ruta	Finance\Budget2027.xlsx	Artefacto o archivo manipulado en INC-02	INC-02	09:02:00	09:21:00

Tipo	Valor / Indicador	Contexto Forense	Incidente	Primer Visto	Ultimo Visto
Archivo/Ruta	net.exe	Artefacto o archivo manipulado en INC-02	INC-02	09:02:00	09:21:00
Archivo/Ruta	powershell.exe	Artefacto o archivo manipulado en INC-02	INC-02	09:02:00	09:21:00
Archivo/Ruta	tar.exe	Artefacto o archivo manipulado en INC-02	INC-02	09:02:00	09:21:00
Cuenta Comprometida	CORP\backupsvc	Identidad utilizada en actividad maliciosa en INC-03	INC-03	09:36:00	09:42:00
Host Afectado	FS-SRV01	Activo corporativo afectado por eventos de INC-03	INC-03	09:36:00	09:42:00
Host Afectado	WS-023	Activo corporativo afectado por eventos de INC-03	INC-03	09:36:00	09:42:00
Archivo/Ruta	powershell.exe	Artefacto o archivo manipulado en INC-03	INC-03	09:36:00	09:42:00
Archivo/Ruta	vssadmin.exe	Artefacto o archivo manipulado en INC-03	INC-03	09:36:00	09:42:00
IP Externa	198.51.100.88	Direccion IP externa involucrada en INC-04 (origen/destino)	INC-04	10:40:00	10:49:18
Cuenta Comprometida	CORP\rrojas	Identidad utilizada en actividad maliciosa en INC-04	INC-04	10:40:00	10:49:18
Host Afectado	FS-SRV01	Activo corporativo afectado por eventos de INC-04	INC-04	10:40:00	10:49:18
Host Afectado	WS-018	Activo corporativo afectado por eventos de INC-04	INC-04	10:40:00	10:49:18
Archivo/Ruta	7z.exe	Artefacto o archivo manipulado en INC-04	INC-04	10:40:00	10:49:18
Archivo/Ruta	C:\Legal*.docx	Artefacto o archivo manipulado en INC-04	INC-04	10:40:00	10:49:18
Archivo/Ruta	C:\Users\Public\archive.7z	Artefacto o archivo manipulado en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/1	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/10	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/11	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18

Tipo	Valor / Indicador	Contexto Forense	Incidente	Primer Visto	Ultimo Visto
URI	/upload/session/12	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/13	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/14	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/15	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/16	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/17	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/18	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/19	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/2	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/20	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/21	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/22	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/3	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/4	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/5	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/6	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/7	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
URI	/upload/session/8	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18

Tipo	Valor / Indicador	Contexto Forense	Incidente	Primer Visto	Ultimo Visto
URI	/upload/session/9	Endpoint o recurso web accedido en INC-04	INC-04	10:40:00	10:49:18
Cuenta Comprometida	CORP\helpdesk	Identidad utilizada en actividad maliciosa en INC-05	INC-05	11:37:00	12:04:00
Host Afectado	APP-SRV01	Activo corporativo afectado por eventos de INC-05	INC-05	11:37:00	12:04:00
Archivo/Ruta	Action=powershell.exe	Artefacto o archivo manipulado en INC-05	INC-05	11:37:00	12:04:00
Archivo/Ruta	C:\ProgramData\updatecheck.ps1	Artefacto o archivo manipulado en INC-05	INC-05	11:37:00	12:04:00
Archivo/Ruta	C:\ProgramData\wuhelper.exe	Artefacto o archivo manipulado en INC-05	INC-05	11:37:00	12:04:00
Archivo/Ruta	ImagePath=C:\ProgramData\wuhelper.exe	Artefacto o archivo manipulado en INC-05	INC-05	11:37:00	12:04:00
Tarea Programada	\Microsoft\Windows\UpdateCheck	Tarea programada creada para persistencia en INC-05	INC-05	11:37:00	11:37:00
Servicio	WinUpdateHelper	Servicio del sistema instalado en INC-05	INC-05	11:38:00	11:38:00
IP Externa	192.0.2.91	Direccion IP externa involucrada en INC-06 (origen/destino)	INC-06	12:10:00	12:15:00
Cuenta Comprometida	IIS APPPOOL\DefaultAppPool	Identidad utilizada en actividad maliciosa en INC-06	INC-06	12:10:00	12:15:00
Host Afectado	WEB-01	Activo corporativo afectado por eventos de INC-06	INC-06	12:10:00	12:15:00
Archivo/Ruta	/uploads/test.aspx	Artefacto o archivo manipulado en INC-06	INC-06	12:10:00	12:15:00
Archivo/Ruta	cmd.exe	Artefacto o archivo manipulado en INC-06	INC-06	12:10:00	12:15:00
URI	/admin/	Endpoint o recurso web accedido en INC-06	INC-06	12:10:00	12:15:00
URI	/api/v1/export	Endpoint o recurso web accedido en INC-06	INC-06	12:10:00	12:15:00
URI	/login?user=admin	Endpoint o recurso web accedido en INC-06	INC-06	12:10:00	12:15:00
URI	/uploads/test.aspx?cmd=whoami	Endpoint o recurso web accedido en INC-06	INC-06	12:10:00	12:15:00

Nota Explicita sobre Hashes Criptograficos:

Hashes de archivos: No disponibles en la telemetria provista. La configuracion de auditoria de creacion de procesos en los registros de seguridad no incluyo la captura de hashes criptograficos (SHA-256 o MD5). Se recomienda desplegar Sysmon con el Event ID 1 configurado para registrar hashes SHA-256 de forma obligatoria.

2.6 Correlacion y Analisis de Atribucion (Metodologia ACH)

Para determinar la naturaleza y origen de los ataques observados, se aplico la metodologia de Analisis de Hipotesis Competitivas (ACH - Analysis of Competing Hypotheses), evaluando sistematicamente la evidencia tecnica frente a tres hipotesis mutuamente excluyentes.

Definicion de Hipotesis Competitivas:

H1: Un unico actor de amenazas coordinado ejecutando una campana de intrusion lineal y estructurada.

H2: Multiples actores de amenazas oportunistas e independientes actuando de manera concurrente.

H3: Un Initial Access Broker (IAB) que obtuvo accesos iniciales y los traspaso o vendio a operadores independientes.

Matriz de Evaluacion de Evidencia vs Hipotesis (ACH):

Evidencia / Factor Observado	H1 (Unico)	H2 (Multiples)	H3 (IAB + Operadores)
Direcciones IP de origen disjuntas por incidente (203.0.113.74, 198.51.100.77, 192.0.2.91, 203.0.113.88, 198.51.100.88)	Inconsistente (-)	Muy Consistente (++)	Consistente (+)
Divergencia radical de TTPs (Spraying masivo vs RDP Brute Force vs Web Shell vs Exfiltracion HTTP vs vssadmin)	Inconsistente (-)	Muy Consistente (++)	Consistente (+)
Ventana de actividad de mgarcia cesa a las 08:40 y nunca vuelve a ser utilizada por otros incidentes	Inconsistente (-)	Consistente (+)	Inconsistente (-)
Ataque externo por fuerza bruta RDP a cuenta admin (redundante e ilogico si un unico actor ya tenia acceso interno)	Muy Inconsistente (--)	Muy Consistente (++)	Consistente (+)
Ausencia total de volcado de credenciales en memoria (LSASS/Mimikatz) en la estacion WS-031 tras el acceso	Inconsistente (-)	Consistente (+)	Consistente (+)

Evaluacion Forense de la Evidencia:
1. Infraestructura de Red Dispar: Cada incidente opera desde una direccion IP publica completamente diferenciada sin solapamiento temporal ni de rangos AS. No se observan pivotes desde las mismas maquinas perimetrales.
2. Redundancia Tactica: La cuenta 'admin' es atacada mediante fuerza bruta RDP externa sobre APP-SRV01 a las 09:15, lo cual resulta operativo y tacticamente redundante para un actor unico que ya habia consolidado acceso con privilegios administrativos en WS-031 a las 08:35.
3. Comportamiento Estanco de Cuentas: La identidad 'mgarcia' queda inerte tras las 08:40. En paralelo, 'backupsvc' y 'rrojas' aparecen en fases posteriores en hosts diferentes sin trazas de movimiento lateral cruzado entre dichas cuentas.
4. Perfil Operacional Heterogeneo: Coexisten tecnicas tipicas de ransomware oportunista (eliminacion ruidosa de vssadmin), ciberespionaje/fuga de datos (exfiltracion silenciosa vía proxy de Legal/Finanzas) y explotacion perimetral web clasica (web shell).

Conclusion Analitica:
La hipotesis H2 (Multiples actores de amenazas oportunistas e independientes) es la mas consistente con el conjunto de evidencias observadas. La hipotesis H3 (Initial Access Broker que traspasa accesos a diferentes operadores) no puede descartarse por completo, dada la secuencia temporal de ciertos accesos. La hipotesis H1 queda practicamente refutada por la redundancia e incompatibilidad de vectores.
Nivel de Confianza: BAJO-MEDIO. Esta estimacion se encuentra estrictamente condicionada por las brechas de visibilidad perimetral (carencia de logs de VPN y firewall) que impiden verificar si existio comparticion de infraestructura a nivel de transporte.

2.7 Calidad de Datos, Telemetria y Brechas de Visibilidad

A continuacion se documentan las brechas de visibilidad identificadas durante el analisis forense, acompanadas de precisiones analiticas criticas sobre asignacion de privilegios y vectores de compromiso.

• Ausencia de Logs de Firewall Perimetral y VPN

No se dispone de registros de conexiones entrantes perimetrales, imposibilitando correlacionar las sesiones de red con identidades VPN, factores de doble autenticacion o intentos de intrusion previos a la capa de aplicacion.

• Carencia de Telemetria EDR / Sysmon sobre LSASS (T1003)

No se cuenta con eventos de acceso a procesos (Sysmon Event ID 10) que permitan constatar o descartar intentos de volcado de memoria del proceso lsass.exe en las estaciones de trabajo comprometidas.

• Falta de Registro de Eventos Kerberos (4768 / 4769)

La ausencia de eventos de emision de TGT (4768) y solicitudes de Ticket de Servicio TGS (4769) genera un punto ciego critico ante tecnicas avanzadas de Kerberoasting, AS-REP Roasting o Pass-the-Ticket.

• Omision de Eventos de Logon con Credenciales Explicitas (4648)

No se auditan inicios de sesion mediante 'RunAs' o inyeccion de credenciales explicitas, dificultando el rastreo fino de elevaciones secundarias en contexto interactivo.

• Falta de Integracion con Inteligencia de Amenazas (CTI / MISP)

Se detecta una dependencia exclusiva de telemetria interna sin contraste automatizado contra fuentes de CTI de la industria energetica europea (recomiendase integracion formal con plataforma MISP y feeds del CSIRT sectorial).

Aclaracion Tecnica Fundamental sobre Evento 4672 (mgarcia):
El registro del Event ID 4672 ('Special privileges assigned to new logon') para la cuenta mgarcia en la maquina WS-031 NO constituyo una escalada tecnica de privilegios durante la sesion. El analisis forense confirma que la cuenta mgarcia YA pertenecia previamente al grupo local de Administradores de la estacion de trabajo, representando una violacion directa del Principio de Menor Privilegio (Least Privilege) en la politica de estaciones de usuario corporativas.

Vector Inicial de Compromiso de backupsvc:
El vector inicial por el cual el adversario obtuvo la credencial de la cuenta 'backupsvc' NO pudo ser determinado a partir de la telemetria disponible. En los eventos de password spraying (INC-01) dicha cuenta fue objeto de intentos fallidos sin exito en el log. Por consiguiente, la credencial fue obtenida fuera de banda (volcado previo no registrado, phishing, reutilizacion de claves o compromiso de repositorio externo).

Anomalias de Calidad de Datos (R14) y Hallazgo Negativo en Active Directory:
La regla R14 identifico discrepancias estructurales: la presencia del hostname 'DC01' (sin guion, frente al canonico 'DC-01') y el uso de la identidad 'CORP\svc_backup' (frente a la cuenta estandar 'CORP\backupsvc').
Hipotesis para Verificacion en Active Directory: Se requiere consultar en el controlador de dominio los atributos 'whenCreated', 'whenChanged', el historial 'sAMAccountName' y el SID del creador del objeto ('objectSid').
Hallazgo Negativo Determinante: No existe ningun evento de creacion ni modificacion de cuentas ni de grupos de seguridad (Event IDs 4720, 4722, 4728, 4732 o 4738) en toda la telemetria provista. Esto confirma que ninguna de estas entidades fue creada en caliente durante la ventana de investigacion.

2.8 Playbook Operativo de Contencion, Erradicacion y Recuperacion

Playbook operacional de ejecucion inmediata para el equipo de respuesta a incidentes (IR / SecOps), con mandatos y comandos tecnicos ejecutables precisos por vector e incidente identificado.

Fase / Incidente	Objetivo Operativo	Comando Tecnico / Accion Ejecutable
INC-01 (Spraying / WS-031)	Aislamiento de Endpoint y Mitigacion de Identidad	1. Aislar maquina via Defender for Endpoint: Invoke-RestMethod -Uri 'https://api.securitycenter.microsoft.com/api/machines/WS-031/isolate' -Method Post 2. Deshabilitar cuenta comprometida: Disable-ADAccount -Identity 'mgarcia' 3. Revocar sesiones activas de M365/Entra ID: Revoke-MgUserSignInSession -UserId 'mgarcia@nordicenergy.se' 4. Bloquear IP de ataque en Firewall perimetral: New-NetFirewallRule -DisplayName 'Block-Attacker-203.0.113.74' -Direction Inbound -Action Block -RemoteAddress 203.0.113.74 5. Remover mgarcia del grupo de Administradores locales: Remove-LocalGroupMember -Group 'Administradores' -Member 'CORP\mgarcia'
INC-02 (RDP Brute Force / APP-SRV01)	Contencion de RDP y Reseteo de Cuenta Administrativa	1. Bloquear IP de origen RDP: New-NetFirewallRule -DisplayName 'Block-Attacker-198.51.100.77' -Direction Inbound -Action Block -RemoteAddress 198.51.100.77 2. Deshabilitar y resetear contraseña de cuenta admin: Disable-ADAccount -Identity 'admin'; Set-ADAccountPassword -Identity 'admin' -Reset 3. Forzar Network Level Authentication (NLA) obligatorio en RDP: Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp' -Name 'UserAuthentication' -Value 1 4. Aislar temporalmente APP-SRV01 para inspeccion forense de memoria.
INC-03 (Pre-Ransomware / FS-SRV01, WS-023)	Proteccion de Almacenamiento y Verificacion de Copias	1. Aislamiento preventivo inmediato de FS-SRV01 y WS-023. 2. Deshabilitar cuenta backupsvc: Disable-ADAccount -Identity 'backupsvc' 3. Verificacion offline de copias de seguridad (WORM / cinta inmutable): Confirmar integridad de respaldos desconectados no alcanzables por vssadmin delete. 4. Restringir acceso al binario vssadmin.exe mediante directiva AppLocker / WDAC.
INC-04 (Exfiltracion Proxy / WS-018)	Interrupcion de Canal de Fuga y Saneamiento de Cuentas	1. Bloquear destino proxy en pasarela perimetral: Set-ProxyBlockRule -Destination '203.0.113.88' -Action Deny 2. Deshabilitar cuenta rrojas y cerrar sesiones activas: Disable-ADAccount -Identity 'rrojas'; Revoke-MgUserSignInSession -UserId 'rrojas@nordicenergy.se' 3. Auditoria forense de archivos accedidos en recursos compartidos Finance y Legal.

Fase / Incidente	Objetivo Operativo	Comando Tecnico / Accion Ejecutable
INC-05 (Persistencia C2 / APP-SRV01)	Erradicacion de Mecanismos de Persistencia y Balizamiento	1. Detener y eliminar servicio malicioso: Stop-Service -Name 'WinUpdateHelper' -Force sc.exe delete WinUpdateHelper 2. Eliminar tarea programada maliciosa: schtasks /delete /tn '\Microsoft\Windows\UpdateCheck' /f 3. Bloquear IP de balizamiento C2: New-NetFirewallRule -DisplayName 'Block-C2-198.51.100.88' -Direction Outbound -Action Block -RemoteAddress 198.51.100.88
INC-06 (Web Shell / WEB-01)	Erradicacion de Web Shell y Blindaje de Servidor Web	1. Aislar de red el servidor web perimetral WEB-01. 2. Detener Application Pool de IIS: Stop-WebAppPool -Name 'DefaultAppPool' 3. Eliminar artefacto web shell: Remove-Item -Path 'C:\inetpub\wwwroot\test.aspx' -Force 4. Bloquear direccion IP atacante: New-NetFirewallRule -DisplayName 'Block-Attacker-192.0.2.91' -Direction Inbound -Action Block -RemoteAddress 192.0.2.91 5. Desplegar reglas de inspeccion WAF para impedir carga y ejecucion remota de scripts.

Anexo A: Reglas de Deteccion y Umbrales Operativos (R1 a R14)

Regla	Nombre Operativo	Umbral / Criterio Tecnico	Severidad	Tactica MITRE
R1	Password Spraying	>= 10 fallos (EID 4625), >= 5 usuarios distintos en ventana de 15 min	Medio	Credential Access
R2	Fuerza Bruta RDP / Logon	>= 3 fallos (EID 4625) en ventana de 10 min sobre el mismo usuario/host	Medio	Credential Access
R3	Exito Tras Ataque	Logon exitoso (EID 4624) dentro de 30 min tras evento R1 o R2	Alto	Initial Access
R4	Logon Anomalo / Administrador	Logon con cuenta de servicio o privilegiada fuera de horario / interactivo	Medio	Initial Access
R5	LOLBins y Comandos Sospechosos	Invocacion de vssadmin delete, tar/zip, whoami, certutil, mimikatz	Alto	Execution / Impact
R6	Movimiento Lateral (RDP/SMB)	Logon Tipo 10 (RDP) o Tipo 3 (SMB) entre estaciones y servidores	Medio	Lateral Movement
R7	Acceso a Datos Sensibles	Acceso a recursos compartidos conteniendo Finance, Legal, HR	Medio	Collection
R8	Acceso Masivo a Archivos	>= 10 eventos de lectura en recursos compartidos en menos de 5 min	Alto	Collection
R9	Exfiltracion via Proxy	Transferencia HTTP POST > 100 MB acumulados en menos de 15 min	Alto	Exfiltration
R10	Doble Extension / Nombres Sospechosos	Ejecucion de archivos con doble extension (.pdf.exe) o nombres aleatorios	Medio	Defense Evasion

Regla	Nombre Operativo	Umbral / Criterio Tecnico	Severidad	Tactica MITRE
R11	Persistencia (Servicios / Tareas)	Creacion de servicios (7045) o tareas programadas (4698) en ProgramData/Temp	Alto	Persistence
R12	Balizamiento C2 Periodico	>= 4 conexiones hacia el mismo destino con fluctuacion (jitter) < 10%	Alto	Command and Control
R13	Web Shell y Sondeo Web	Peticiones a .aspx/.php con parametros cmd= o > 10 sondeos en 5 min	Alto	Persistence / Initial Access
R14	Anomalia en Calidad de Datos	Discrepancias de formato (DC01 vs DC-01, svc_backup) o corrupcion de logs	Bajo	Operacional

Anexo B: Glosario de Event IDs y Fuentes de Log Utilizadas

Event ID	Fuente de Telemetria	Nombre del Evento	Relevancia Operativa SOC L2
4624	Security Log	An account was successfully logged on	Identificacion de inicios de sesion, tipo de logon (3, 10) e IP origen.
4625	Security Log	An account failed to log on	Deteccion de ataques de password spraying y fuerza bruta remota.
4672	Security Log	Special privileges assigned to new logon	Asignacion de privilegios administrativos en sesion (least privilege check).
4688	Security Log	A new process has been created	Rastreo de ejecucion de procesos interactivos y argumentos LOLBins.
4698	Security Log	A scheduled task was created	Deteccion de mecanismos de persistencia basados en tareas del sistema.

Event ID	Fuente de Telemetria	Nombre del Evento	Relevancia Operativa SOC L2
4702	Security Log	A scheduled task was updated	Monitoreo de alteraciones en configuraciones de persistencia existentes.
5140	Security Log	A network share object was accessed	Inspeccion de acceso a carpetas compartidas en servidores de red.
5145	Security Log	A network share object was checked	Auditoria detallada de archivos accedidos en recursos sensibles.
7045	System Log	A service was installed in the system	Identificacion de persistencia y elevacion mediante servicios de Windows.
HTTP_ACCESS	Web Server (IIS)	Inbound HTTP Request	Deteccion de explotacion de vulnerabilidades web y ejecucion de web shells.
PROXY_LOG	Proxy Corporativo	Outbound HTTP/HTTPS Traffic	Monitoreo de transferencias masivas de datos y balizamiento periodico C2.